ТЕМА 1.13 · ТЕКСТ ВЫСТУПЛЕНИЯ

Эталоны и отступы в обнаружении SYN-flood

20 слайдов · 15–20 минут · для студентов ИБ · учебные данные

СЛАЙД 01

Эталоны и отступы в обнаружении SYN-flood

Точная тема работы — «1.13. Понятие эталона. Отступы и классификация объектов качества». Рассмотрим её на понятной для информационной безопасности задаче: отличить обычный трафик от SYN-flood. Вместо большого количества формул будем отвечать на три вопроса. На какой типичный пример похож трафик? Как модель проводит границу между классами? Насколько близко наблюдение находится к смене решения? Последний вопрос поможет объяснить «запас прочности». Сразу обозначим масштаб результата: подготовлен учебный эксперимент с вымышленными данными и воспроизводимыми расчётами. Мы не запускали атаку и не внедряли детектор в рабочую сеть. Подробная математика и код вынесены в Google Colab, а здесь главное — смысл результатов для специалиста ИБ.

СЛАЙД 02

Структура работы: теория, задание, практика

Доклад организован по трём критериям, каждый из которых оценивается в пять баллов. Это карта содержания, а не обещание получить определённую оценку. Теоретическая часть — слайды с третьего по седьмой: механизм атаки, измеряемые признаки, эталон, отступ и машинное обучение. Выполнение задания — слайды с восьмого по четырнадцатый: выборка, выбранные эталоны, обученная модель, конкретные решения и пограничные случаи. Практическая часть — слайды с пятнадцатого по восемнадцатый: место модели в работе аналитика, демонстрация функции в Colab, проверка тревоги и план реального испытания. В конце свяжем все части. Такая структура позволяет отдельно показать знание понятий, выполненные расчёты и понимание того, как применять результат в ИБ.

СЛАЙД 03

SYN-flood: почему страдает сервер

Обычное TCP-соединение начинается с обмена тремя сообщениями: клиент отправляет SYN, сервер отвечает SYN-ACK, клиент подтверждает ответ сообщением ACK. Этот обмен называют рукопожатием: стороны согласуют начало соединения. При SYN-flood сервер получает множество попыток, которые не доходят до завершения. Если для них хранится состояние, очередь незавершённых подключений и ресурсы сервера могут оказаться заняты. Тогда обычным пользователям становится труднее подключиться. Для обнаружения полезно одновременно смотреть на количество SYN и долю незавершённых попыток. Одного большого количества запросов недостаточно: так выглядит и легитимный всплеск посещаемости. А незавершённость бывает связана с потерями или задержками сети. Именно поэтому в задаче нужны два признака и проверка неоднозначных ситуаций.

СЛАЙД 04

Что видит детектор

Один объект для классификации — десятисекундное окно трафика к конкретному IP-адресу и порту сервера. Из него получаем два числа: среднее количество входящих SYN в секунду и процент незавершённых попыток соединения. Скорость считает все SYN, включая повторы. Для доли попыток повторы, наоборот, объединяются: повтор одного запроса не должен становиться новым соединением. Попытку считаем незавершённой, если за три секунды после начального SYN не наблюдаем полное рукопожатие. Поэтому последним попыткам окна нужно дать дополнительное время; признак получается с задержкой. Окна без SYN исключаем, чтобы не делить на ноль. Наблюдатель должен видеть оба направления обмена: иначе отсутствие подтверждения может оказаться отсутствием видимости, а не проблемой соединения.

СЛАЙД 05

Эталон — типичный представитель класса

Представим два образца: обычную работу сервиса и SYN-flood. Эталон нужен, чтобы сравнивать новое наблюдение с характерным представителем каждого класса. Здесь это не самый безопасный сервер и не максимально сильная атака, а типичный объект нашей выборки. Для выбора используем медоид. Простыми словами, перебираем примеры одного класса и ищем тот, который в сумме ближе всего к остальным. Поэтому эталон обязательно совпадает с одним из обучающих примеров. Это удобно для объяснения: можно показать конкретную скорость и долю незавершённых соединений. Правило близости зависит от масштаба признаков. Если обычный трафик имеет несколько разных режимов, одного эталона может оказаться недостаточно. В работе берём по одному для наглядного учебного сравнения.

СЛАЙД 06

Отступ простым языком

После выбора правила появляется граница: по одну сторону модель говорит «норма», по другую — «атака». Если наблюдение почти на границе, небольшое изменение его признаков может изменить ответ. Если далеко — для изменения ответа потребуется большее изменение признаков. Это и есть идея запаса прочности решения. Для нового трафика нам доступно расстояние до границы, но настоящая метка обычно неизвестна. В учебных данных метку знаем, поэтому можем дополнительно проверить правильность: положительный размеченный отступ соответствует верному ответу, отрицательный — ошибке. Малое расстояние означает пограничность и встречается у обоих классов. Оно не является вероятностью атаки. Большое расстояние также не подтверждает правильность: модель может устойчиво ошибаться.

СЛАЙД 07

SVM с мягким зазором

SVM, или машина опорных векторов, — метод, который обучается разделять классы по размеченным примерам. В нашем случае он строит прямую на плоскости двух признаков. Метод старается оставить вокруг неё полосу, отделяющую типичные решения от трудных. Мягкий зазор означает, что отдельным обучающим объектам разрешено попадать внутрь этой полосы, а иногда и на неверную сторону. Это компромисс, которым управляет параметр C. Для демонстрации заранее выбрали C, равное единице; это не универсальная настройка защиты. Опорные векторы — обучающие примеры, участвующие в определении границы. Их не следует путать с эталонами: эталон представляет класс, а опорные примеры влияют на решение модели. Формулы оптимизации доступны в ноутбуке.

СЛАЙД 08

Учебный эксперимент: 20 примеров и 8 проверок

Для эксперимента вручную составлены двадцать обучающих объектов: десять нормальных и десять атакующих. Дополнительно выбраны восемь проверочных примеров, среди которых есть очевидные и неоднозначные ситуации. Проверочные объекты не участвовали в выборе эталонов или обучении модели. Но это всё равно не полноценный тест детектора: данные синтетические, малочисленные и специально подобраны для объяснения. Они позволяют проверить расчёты и увидеть ошибки, а не заявить качество на реальной сети. Все координаты, классы и шаги доступны в Google Colab — онлайн-ноутбуке, где можно выполнить код последовательно. Никаких сетевых запросов атаки он не отправляет: обрабатывает только числовую таблицу. Поэтому результат можно воспроизвести на занятии без проведения SYN-flood.

СЛАЙД 09

Выбранные эталоны двух классов

По обучающим объектам алгоритм выбрал нормальный эталон N05: 600 SYN в секунду и 15 процентов незавершённых попыток. Эталон атакующего класса — A06: 1300 SYN в секунду и 65 процентов незавершённых попыток. Эти числа описывают характерные примеры именно нашей таблицы. Они не устанавливают правило «1300 — всегда атака», потому что интенсивность зависит от сервиса и обычной нагрузки. В ноутбуке показан перебор кандидатов и сумма расстояний для каждого. Сначала можно понять результат по исходным единицам, а затем проверить вычисление. При классификации по эталонам выбирается ближайший представитель. Это простое объяснимое правило полезно как отправная точка; далее сравниваем его с границей, обученной на всех двадцати примерах.

СЛАЙД 10

Обучение модели в Colab

В ноутбуке используем линейный SVC из библиотеки scikit-learn — готовую реализацию классификатора SVM. Сначала отделяем обучающие строки от проверочных. Затем переводим признаки в согласованный масштаб: количество SYN в секунду делим на тысячу, а процент незавершённых попыток — на сто. Например, 900 SYN и 40 процентов превращаются в числа 0,90 и 0,40. Этот масштаб выбран заранее, поэтому ничего не подгоняется по проверочным объектам. После обучения модель выдаёт класс и позволяет вычислить расстояние до границы. Колаб хранит коэффициенты, подробный расчёт отступа и таблицу всех восьми проверок. Для понимания результата достаточно помнить: мы подаём два измерения, получаем прогноз и отдельно оцениваем его близость к смене ответа.

СЛАЙД 11

Как выглядит граница SVM

На диаграмме показаны двадцать обучающих наблюдений. По горизонтали — реальное количество SYN в секунду, по вертикали — процент незавершённых попыток. Цвета обозначают известные учебные классы. Центральная прямая показывает, где модель меняет прогноз между нормой и SYN-flood. Серая полоса и её штриховые границы выделяют учебную область перепроверки: расстояние до границы решения меньше 0,10. Само расстояние по-прежнему вычисляется в масштабированных признаках, как в ноутбуке. Внутри этой области могут оказаться оба класса, поэтому она помогает заметить пограничные решения. Изображение объясняет поведение конкретной модели, однако хорошее разделение этих точек ещё не доказывает качество в рабочей сети. Для этого нужны другие данные и отдельная проверка, к которой вернёмся в практической части.

СЛАЙД 12

Четыре примера решений

Сравним четыре наблюдения в исходных понятных единицах. T01: 420 SYN в секунду, 9 процентов незавершённых попыток. Это нормальный объект, модель верно отвечает «норма», расстояние около 0,551. T02: 1550 SYN и 88 процентов. Это атака, прогноз верен, расстояние около 0,697. T04: 900 SYN и 40 процентов. По учебной метке это атака, но модель отвечает «норма»; расстояние всего 0,043. T05: 1000 SYN и 42 процента. Это нормальный объект, а модель считает его атакой; расстояние около 0,024. Числа расстояния выражены в выбранном масштабе признаков, не в процентах уверенности. Два последних примера специально показывают ошибки разных типов рядом с границей.

СЛАЙД 13

Две ошибки и их значение для ИБ

Ошибка T04 — пропуск атаки. По-английски это false negative, сокращённо FN: вредоносный объект получил ответ «норма». Для ИБ это риск оставить атаку без нужного внимания. Ошибка T05 — ложная тревога, false positive или FP: обычный трафик получил ответ «атака». Это нагрузка на аналитиков, а при необоснованной блокировке — риск помешать пользователям. В лабораторной таблице мы знаем истинные метки и поэтому можем назвать ошибки. Для нового наблюдения такой готовой подсказки обычно нет. Модель предоставляет сигнал для анализа, а не подтверждённый инцидент. При настройке нужно учитывать обе цены ошибок: большое число тревог не равнозначно хорошей защите, а редкие тревоги не гарантируют, что атаки не пропускаются.

СЛАЙД 14

Пограничные случаи: дополнительная проверка

Для учебного примера выделяем наблюдения с расстоянием меньше 0,1. Среди восьми проверок это T03, T04, T05 и T06. Порог выбран для демонстрации; его нельзя переносить в другую сеть без проверки. Флаг пограничности ставится для обоих прогнозов, поэтому позволяет заметить и сомнительную «норму». Такие объекты можно помещать в дополнительную очередь проверки. Это отдельное правило, а не единственный способ формирования тревог. Если модель прогнозирует атаку далеко от границы, большое расстояние не отменяет сигнал об атаке. Внутри пограничной очереди удобно сначала смотреть ближайшие к границе случаи. Общий приоритет работы аналитика также зависит от критичности сервиса и других признаков инцидента. Отступ помогает организовать анализ, но не заменяет эти решения.

СЛАЙД 15

Где модель полезна специалисту ИБ

Рассмотрим возможный процесс применения. Сначала средство наблюдения собирает сетевую телеметрию — измерения происходящего в сети. Из неё каждые десять секунд формируются два признака для нужного сервера. Модель выдаёт прогноз, а расстояние даёт дополнительный флаг пограничности. Результаты поступают аналитику SOC. SOC — центр мониторинга информационной безопасности, где специалисты проверяют события и разбирают возможные инциденты. Это схема учебного прототипа первичной сортировки, а не описание выполненного внедрения. Сигнал об атаке и запрос проверки пограничного случая нужно хранить отдельно. Атака, предсказанная далеко от границы, тоже требует предусмотренной реакции. Новых истинных меток заранее нет: их получают позднее из расследования, контролируемого эксперимента или подтверждённой разметки. Эти сведения нужны и для последующего улучшения модели.

СЛАЙД 16

Демонстрация первичной сортировки в Colab

В ноутбуке функция triage выполняет первичную сортировку одного наблюдения. Передаём ей скорость SYN и процент незавершённых попыток; получаем прогноз и два отдельных флага. Для входа 900 и 40 результат: predicted_class=«норма», attack_alert=False, boundary_review=True. Это означает «прогноз норма, сигнала атаки от модели нет, пограничная проверка нужна». Для 1550 и 88 результат: predicted_class=«SYN-flood», attack_alert=True, boundary_review=False. Здесь модель сообщает об атаке, а дополнительный флаг пограничности не ставится. Отсутствие этого флага не означает отсутствие опасности и не отменяет тревогу об атаке. Два вызова повторяют выбранные учебные примеры, поэтому не являются проверкой общей точности. Их задача — показать, как превратить класс и расстояние в понятные отдельные выходы для дальнейшего анализа.

СЛАЙД 17

Действия ИБ после сигнала

Получив сигнал, аналитик проверяет контекст. Совпало ли время всплеска с ростом посещаемости или плановыми работами? Видны ли на сервере незавершённые подключения и признаки перегрузки очереди? Есть ли потери сети или пропуски в сборе трафика? Полезно сравнить несколько соседних окон, посмотреть сетевые и серверные журналы, сопоставить события с другими средствами обнаружения. Если TCP-соединения принимает и завершает балансировщик — узел, распределяющий запросы между серверами, — клиентские и серверные соединения анализируют отдельно. Если подозрение подтверждается, с технической командой проверяют настройки SYN cookies и политику ограничений. SYN cookies — механизм, помогающий серверу уменьшить потребность в хранении состояния незавершённых соединений. Уместность и ограничения мер зависят от среды. Наш прототип не принимает решение об автоматической блокировке: по двум признакам нельзя обоснованно выбрать всю реакцию. Проверка нужна как для пограничных наблюдений, так и для сигналов атаки.

СЛАЙД 18

Как проверить метод на реальном трафике

Для следующего этапа нужны записи пакетов с обоими направлениями обмена и подтверждённые метки. Формат PCAP хранит такие записи; один из возможных источников исследования — CICDDoS2019. Наш эксперимент этот набор не использовал. Обучение, настройку и итоговую проверку разделяют по времени и сеансам, чтобы связанные примеры не оказались одновременно в разных частях. Эталоны и любые оцениваемые преобразования строят по обучению; C и порог пограничности выбирают на валидации — отдельной части для настройки. Затем измеряют precision: какая доля тревог действительно связана с атакой; recall: какую долю атак нашли; FPR: какую долю нормальных окон ошибочно сочли атакой. Дополнительно оценивают задержку и размер очереди ручной проверки. В этой работе реального испытания не проводили.

СЛАЙД 19

Как представить результат по трём критериям

По теории можно объяснить три различия своими словами. Эталон — типичный представитель класса; модель — правило, проводящее границу; запас прочности — расстояние до смены её текущего решения, а не вероятность атаки. По выполнению задания можно показать конкретные эталоны N05 и A06, обученную SVM, таблицу решений и четыре пограничных примера. По практике — запустить Colab, получить отдельно сигнал атаки и запрос пограничной проверки, объяснить действия аналитика и план настоящего испытания. Главный вывод для ИБ: одного ответа «норма» или «атака» недостаточно. Нужно понимать, как он получен, какие наблюдения близки к границе, какие ошибки возможны и какими независимыми наблюдениями проверять ситуацию перед реакцией.

СЛАЙД 20

Источники и материалы

Теория SVM опирается на статью Кортеса и Вапника, конспект Stanford CS229 и официальную документацию scikit-learn. Медоиды описаны в работе Шуберта и Руссеу. Механизм SYN-flood и меры противодействия рассматриваются в RFC 4987. Работа DeepFool помогает связать границу классификатора с минимальным изменением признаков; здесь используем понятный линейный случай. CICDDoS2019 указан как возможный источник будущего исследования, а руководство NIST SP 800-94 — как материал об обнаружении вторжений и работе с тревогами. Это руководство опубликовано в 2007 году, поэтому его роль здесь — общие понятия, а не текущая инструкция по настройке конкретного продукта. Все численные примеры и расчёты нашего доклада являются учебными и доступны в ноутбуке.

ИСТОЧНИКИ И МАТЕРИАЛЫ

Использованные источники

Ссылки ниже активны. Численные таблицы презентации относятся к авторскому учебному примеру.

01 Support-vector networks

C. Cortes, V. Vapnik. Machine Learning, 1995.

doi.org/10.1007/BF00994018

02 CS229: Support Vector Machines

Stanford University. Конспект лекций.

see.stanford.edu · PDF

03 Faster k-Medoids Clustering: Improving the PAM, CLARA, and CLARANS Algorithms

E. Schubert, P. J. Rousseeuw. 2018; редакция 2019.

arxiv.org/abs/1810.05691

04 RFC 4987. TCP SYN Flooding Attacks and Common Mitigations

W. Eddy. IETF, 2007.

rfc-editor.org · RFC 4987

05 Support Vector Machines — scikit-learn

Официальная документация: линейные SVM, мягкий зазор и параметр C.

scikit-learn.org · документация

06 DeepFool: A Simple and Accurate Method to Fool Deep Neural Networks

S.-M. Moosavi-Dezfooli, A. Fawzi, P. Frossard. CVPR, 2016.

cv-foundation.org · публикация PDF

07 CICDDoS2019

Canadian Institute for Cybersecurity, University of New Brunswick. Страница датасета.

unb.ca/cic · CICDDoS2019

08 NIST SP 800-94. Guide to Intrusion Detection and Prevention Systems (IDPS)

K. Scarfone, P. Mell. NIST, 2007.

csrc.nist.gov · SP 800-94